

VAPT Internship | Week 1 Challenge: Observation Note

Target Application: OWASP Juice Shop (Hosted Instance)

Analyzed By: Satyam Shiv

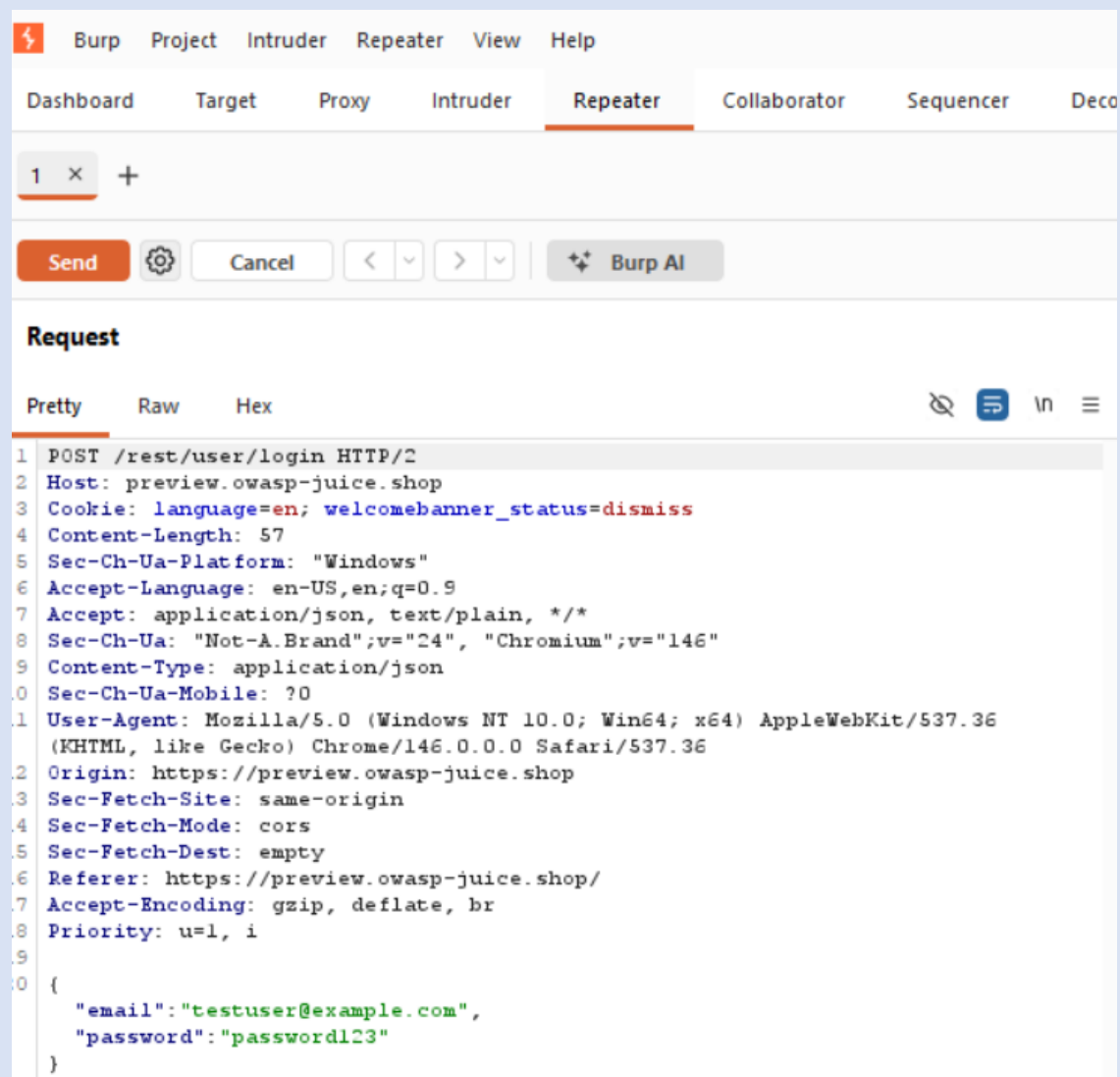
Objective: Intercept authentication traffic using Burp Suite to analyze the HTTP structure and assess credential handling security.

1. Executive Summary

During the Week 1 assessment, I successfully intercepted the login workflow of the target application using Burp Suite Proxy. The application bypasses traditional form submissions in favor of a modern, API-driven architecture, handling authentication via asynchronous background requests.

2. Technical Analysis (Request Breakdown)

As captured , the request possesses the following core HTTP characteristics:



- **Request Line:** POST /rest/user/login HTTP/2
 - *Insight:* The POST method safely keeps credentials out of the URL string, while the use of HTTP/2 indicates support for modern multiplexed streaming performance.
- **Host Header:** preview.owasp-juice.shop
- **Content-Type:** application/json
 - *Insight:* Explicitly instructs the backend API server to parse the incoming body data as a JSON object.
- **Pre-Auth State:** The presence of Cookie: language=en; welcomebanner_status=dismiss confirms that the application tracks user browser state prior to authentication.

3. Payload & Parameter Inspection

At the bottom of the request body, the parameters are passed as a raw JSON object:

JSON

```
{  
  "email": "testuser@example.com",  
  "password": "password123"  
}
```

- **Critical Observation:** The email and password variables are transmitted in **cleartext**. No client-side obfuscation, hashing, or frontend encryption is applied to the payload before it leaves the browser.

4. Security Vulnerability & Risk Assessment

- **Vulnerability Identified:** Cleartext Transmission of Sensitive Credentials.
- **Intern Analysis:** Because the application passes credentials in plaintext within the JSON body, the security of this workflow rests entirely on the Transport Layer (TLS/HTTPS).
- **Impact:** While secure over HTTPS, if this exact API configuration were deployed over an unencrypted channel (http://), it would be highly susceptible to credential sniffing and man-in-the-middle (MITM) attacks, leading to instant account takeover.

5. Proof of Concept (Evidence)

This screenshot shows the HTTP history tab in Burp Suite. The selected request is a GET request to `https://preview.owasp-juice.shop/#/login`. The request details are as follows:

Time	Type	Direction	Method	URL	Status code	Length
01:01:24.25	HTTP	→ Request	GET	https://preview.owasp-juice.shop/#/login		
01:01:31.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:01:38.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:01:43.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:01:48.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:01:53.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:01:58.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:02:05.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:02:10.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:02:15.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:02:20.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:02:25.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:02:30.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:02:36.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:02:41.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:02:46.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		
01:02:51.25	HTTP	→ Request	GET	http://detectportal.firefox.com/canonical.html		

The request details pane shows the following information:

- Request attributes: 2
- Request query parameters: 0
- Request body parameters: 0
- Request cookies: 0
- Request headers: 15

This screenshot shows the login page of the OWASP Juice Shop. The page has a dark theme and includes the following elements:

- Header: OWASP Juice Shop logo, search icon, Account link, Your Basket (0 items), and EN language selector.
- Form: A login form with fields for Email (testuser@example.com) and Password (password123). Below the password field is a "Forgot your password?" link.
- Buttons: "Log in" button, "Remember me" checkbox, and "Log in with Google" button.
- Footer: "Not yet a customer?" link.
- Cookie Notice: A blue banner at the bottom right stating "This website uses fruit cookies to ensure you get the juiciest tracking experience. But me wait!" with a "Me want it!" button.

This screenshot shows the Repeater tab in Burp Suite. The selected request is a POST request to `https://preview.owasp-juice.shop/#/login`. The request details are as follows:

Time	Type	Direction	Method	URL	Status code	Length
01:01:24.25	HTTP	→ Request	POST	https://preview.owasp-juice.shop/#/login		

The request details pane shows the following information:

- Request attributes: 2
- Request query parameters: 0
- Request cookies: 2
- Request headers: 21

The request body is shown in the "Raw" tab:

```
{
  "email": "testuser@example.com",
  "password": "password123"
}
```